GRC CONTROL MAPPING

Futer Exp | GRC Program

Version 1.0 | March 2026 | Classification: Internal / Portafolio Use

Document Owner	Approved By	Review Cycle	Next Review
CISO / Risk Manager	Executive Committee	Annual	March 2027

1. Purpose and Scope

This document maps Futer Exp's internal security controls to four regulatory and standards frameworks: NIST Cybersecurity Framework (CSF 2.0), ISO/IEC 27001:2022 Annex A, NIS2 Directive (EU 2022/2555), and DORA (EU 2022/2554). It provides a unified view of control coverage, ownership, and implementation status to support audit readiness, gap analysis, and continuous improvement.

Coverage legend:

- ✓ Full coverage — control is implemented and documented
- ◑ Partial coverage — control is partially implemented or in progress
- – Not applicable — framework requirement does not apply to this control domain

Risk Scoring Methodology

Control implementation status and gap prioritisation in this document are informed by the Futer Exp Cybersecurity Risk Register (v2.0). Inherent risk scores are calculated as **Risk Score = Likelihood (1–4) × Impact (1–4)**.

Score	Level	Response
12–16	**Critical**	Immediate action required
8–11	**High**	Priority remediation
4–7	**Medium**	Scheduled remediation
1–3	**Low**	Monitor

Control owners should reference the Risk Register (v2.0) for full risk treatment plans, residual scores, and remediation tracking.

2. Framework Reference Summary

Framework	Versión	Key Domains Referenced	Applicability
NIST CSF	CSF 2.0 (2024)	Govern, Identify, Protect, Detect, Respond, Recover	All organizations — primary cybersecurity framework
ISO/IEC 27001	ISO 27001:2022	Annex A Controls A.5–A.8 (Organizational, People, Physical, Technological)	Certification target — aligns with ISMS requirements
NIS2	EU 2022/2555	Art. 21 — Risk management, incident handling, supply chain, continuity	Essential & important entities operating in the EU
DORA	EU 2022/2554	ICT risk management, incident reporting, third-party risk, resilience testing	Financial entities & ICT service providers in the EU

3. Control Mapping

Controls are grouped by domain. Each row shows the control ID, name, description, owner, framework coverage, implementation status, and notes.

ID	Control	Description	Owner	NIST CSF	ISO 27001	NIS 2	DORA	Status	Notes
DOMAIN 1 — Governance & Risk Management									
G-01	**Security Policy**	Formal information security policy approved by leadership and communicated to all staff. Reviewed annually.	CISO	GV.PO	A.5.1	Art.21	Art.5	**Implemented**	Last reviewed March 2026
G-02	**Risk Assessment Process**	Documented risk methodology using Impact × Likelihood scoring. Risk register maintained and reviewed quarterly.	Risk Mgr	GV.RM / ID.RA	A.8.2	Art.21	Art.6	**Implemented**	Aligned with NIST CSF 2.0

G-03	**Roles & Responsibilities**	RACI matrix defining security roles across all GRC activities. CISO and risk owner designations formalized.	CISO	GV.RR	A.5.2	Art.20	–	**Implemented**	RACI doc published March 2026
G-04	**Compliance Monitoring**	Ongoing tracking of regulatory obligations (GDPR, NIS2, DORA). Annual compliance review cycle.	Risk Mgr	GV.OC	A.5.36	Art.21	Art.5	**In Progress**	NIS2/DORA gap assessment underway
G-05	**Security Awareness Training**	Annual mandatory security training for all staff. Phishing simulation conducted quarterly.	HR / CISO	PR.AT	A.6.3	Art.21	–	**In Progress**	Training programme being formalized
G-06	**Internal Audit**	Annual internal audit of GRC controls against ISO 27001 and NIST benchmarks.	Risk Mgr	GV.OV	A.5.35	Art.21	Art.5	**Planned**	First audit scheduled Q3 2026
DOMAIN 2 — Asset Management									
A-01	**Asset Inventory**	Register of all information assets including hardware, software, cloud services, and data. Owner assigned per asset.	IT Ops	ID.AM	A.5.9	Art.21	Art.8	**Implemented**	Asset register integrated with risk register
A-02	**Data Classification**	Data classified as Public, Internal, Confidential, or Restricted. Handling rules defined per classification level.	Risk Mgr	ID.AM	A.5.12	Art.21	–	**Implemented**	Classification scheme documented
A-03	**Asset Lifecycle Management**	Formal process for procurement, change, and secure disposal of assets. Decommissioning includes data wiping.	IT Ops	ID.AM	A.5.9 / A.7.14	Art.21	–	**In Progress**	Disposal procedure being finalized
DOMAIN 3 — Access Control & Identity									
AC-01	**Identity & Access Management**	Role-based access control (RBAC) implemented across all systems. Least-privilege principle enforced.	IT Ops	PR.AA	A.8.2 / A.8.3	Art.21	Art.9	**Implemented**	AWS IAM policies configured
AC-02	**Multi-Factor Authentication**	MFA enforced for all remote access, privileged accounts, and cloud console access.	IT Ops	PR.AA	A.8.5	Art.21	Art.9	**Implemented**	MFA active on AWS, VPN, SaaS tools

AC-03	**Privileged Access Management**	Separate privileged accounts for admins. PAM controls limit standing access; JIT access in scope.	IT Ops	PR.AA	A.8.2	Art.21	Art.9	**In Progress**	JIT access tooling being evaluated
AC-04	**Access Review**	Periodic review of user access rights. Leavers deprovisioned within 24 hours of departure.	IT Ops / HR	PR.AA	A.8.2	Art.21	–	**Implemented**	Quarterly access review process in place
AC-05	**Remote Access Security**	VPN required for all remote connections. Split-tunnelling disabled. ZTNA roadmap in planning.	IT Ops	PR.AA	A.8.20	Art.21	–	**Implemented**	Zero-trust evaluation Q4 2026
DOMAIN 4 — Network & Infrastructure Security									
NI-01	**Network Segmentation**	Production, development, and test environments isolated. AWS VPC with subnet-level controls.	IT Ops	PR.IR	A.8.20 / A.8.22	Art.21	Art.9	**Implemented**	VPC segmentation documented
NI-02	**Firewall & Perimeter Controls**	WAF, security groups, and NACLs in place. Inbound rules reviewed quarterly.	IT Ops	PR.IR	A.8.20	Art.21	–	**Implemented**	AWS Security Groups + WAF active
NI-03	**Vulnerability Management**	Automated vulnerability scanning monthly. Critical findings patched within 72 hours; high within 30 days.	IT Ops	ID.RA	A.8.8	Art.21	Art.21	**Implemented**	Scanning tool: AWS Inspector
NI-04	**Penetration Testing**	Annual external penetration test by qualified third party. Internal testing conducted quarterly.	CISO	ID.RA	A.8.8	Art.21	Art.26	**Planned**	First pentest scheduled Q2 2026
NI-05	**Patch Management**	Automated patching for OS and critical dependencies. Patch status tracked in asset register.	IT Ops	PR.MA	A.8.8	Art.21	–	**Implemented**	AWS Systems Manager for patching
NI-06	**Endpoint Protection**	EDR solution deployed on all managed endpoints. USB and removable media restricted.	IT Ops	PR.PS	A.8.7	Art.21	–	**In Progress**	EDR rollout 80% complete

DOMAIN 5 — Data Protection & Cryptography									
DP-01	**Encryption at Rest**	All sensitive data encrypted at rest using AES-256. AWS S3 server-side encryption enabled by default.	IT Ops	PR.DS	A.8.24	Art.21	Art.9	**Implemented**	S3 SSE-KMS configured
DP-02	**Encryption in Transit**	TLS 1.2+ enforced for all data in transit. HTTP traffic redirected to HTTPS. Legacy protocols disabled.	IT Ops	PR.DS	A.8.24	Art.21	–	**Implemented**	TLS enforced on all endpoints
DP-03	**Key Management**	Encryption keys managed via AWS KMS. Key rotation enforced annually. Access to KMS logged.	IT Ops	PR.DS	A.8.24	Art.21	–	**Implemented**	KMS with CloudTrail logging
DP-04	**Data Loss Prevention**	DLP controls on email and cloud storage. Sensitive data transfer to personal accounts blocked.	IT Ops	PR.DS	A.8.12	Art.21	–	**In Progress**	DLP policy being finalized
DP-05	**Backup & Recovery**	Daily automated backups of all critical systems. Backups encrypted, stored in separate AWS region, tested quarterly.	IT Ops	RC.RP	A.8.13	Art.21	Art.11	**Implemented**	Cross-region backup active
DOMAIN 6 — Incident Response & Detection									
IR-01	**Security Monitoring (SIEM)**	Centralized log collection and correlation via Splunk. Alerts configured for critical threat categories.	IT Ops	DE.CM	A.8.15 / A.8.16	Art.21	Art.10	**Implemented**	Splunk SIEM operational
IR-02	**Incident Response Plan**	Documented IRP with defined roles, escalation paths, and communication procedures. Tested semi-annually.	CISO	RS.RP	A.5.26	Art.21	Art.10	**Implemented**	IRP v1.1 — last test Jan 2026
IR-03	**Incident Classification**	Incidents classified by severity (P1–P4) with defined response SLAs. P1 requires CISO notification within 1 hour.	Risk Mgr	RS.RP	A.5.25	Art.21	Art.10	**Implemented**	Severity matrix in IRP
IR-04	**Regulatory Incident Reporting**	Process to notify regulators within 24 hours (NIS2/DORA significant incidents) and 72 hours (GDPR breaches).	CISO	RS.CO	A.5.26	Art.23	Art.19	**In Progress**	Reporting templates in draft

IR-05	**Forensics & Evidence Preservation**	Log retention minimum 12 months. Chain-of-custody procedures for digital forensic evidence.	IT Ops	RS.AN	A.8.15	Art.21	–	**Implemented**	CloudTrail + Splunk 12-month retention
DOMAIN 7 — Business Continuity & Resilience									
BC-01	**Business Continuity Plan**	BCP covering critical business functions with defined RTOs and RPOs. Approved by executive committee.	Risk Mgr	RC.RP	A.5.29	Art.21	Art.11	**In Progress**	BCP v0.9 — final review pending
BC-02	**Disaster Recovery**	DR plan for critical IT systems. Failover to secondary AWS region. DR tests conducted annually.	IT Ops	RC.RP	A.8.13	Art.21	Art.11	**In Progress**	DR test scheduled Q3 2026
BC-03	**Resilience Testing**	Annual scenario-based resilience exercises including tabletop simulations for cyber incidents.	CISO	RC.IM	A.5.30	Art.21	Art.26	**Planned**	First exercise Q4 2026
DOMAIN 8 — Third-Party & Supply Chain Risk									
TP-01	**Third-Party Risk Framework**	Formal TPRF with 4-tier vendor classification, due diligence requirements, and lifecycle management.	Risk Mgr	GV.SC	A.5.19	Art.21	Art.28	**Implemented**	TPRF v1.0 published March 2026
TP-02	**Vendor Security Assessment**	Pre-onboarding security questionnaire (VSQ) for all vendors. Tier 1/2 require annual reassessment.	Risk Mgr	ID.SC	A.5.20	Art.21	Art.28	**Implemented**	VSQ v1.0 published March 2026
TP-03	**Contractual Security Requirements**	DPA, audit rights, incident notification SLAs, and sub-processor disclosure included in all vendor contracts.	Legal	GV.SC	A.5.20	Art.28(GDPR)	Art.30	**Implemented**	Standard clauses in all new contracts
TP-04	**Critical ICT Provider Register**	Register of critical ICT third parties maintained per DORA Art. 28. Includes concentration risk assessment.	Risk Mgr	GV.SC	A.5.19	Art.21	Art.28	**In Progress**	Register being populated
TP-05	**Vendor Offboarding**	Formal offboarding checklist: access revocation, data deletion	IT Ops / Risk	GV.SC	A.5.19	Art.21	–	**Implemented**	Checklist embedded in TPRF

		confirmation, and lessons-learned review.							
DOMAIN 9 — Physical & Environmental Security									
PH-01	**Physical Access Controls**	Office access restricted by key card. Server rooms require dual-factor physical entry. Visitor log maintained.	Facilities	PR.AA	A.7.1 / A.7.2	Art.21	–	**Implemented**	Access log reviewed monthly
PH-02	**Clean Desk & Screen Lock**	Clean desk policy enforced. Workstations auto-lock after 5 minutes of inactivity.	IT Ops / HR	PR.PS	A.7.7 / A.7.8	Art.21	–	**Implemented**	Policy published and enforced
PH-03	**Environmental Controls**	UPS, fire suppression, and temperature monitoring in server areas. Cloud-primary reduces physical risk.	Facilities	PR.IR	A.7.5	–	–	**Implemented**	AWS handles primary infra

4. Gap Summary

The following controls require priority attention based on current implementation status:

Control ID	Control Name	Gap Description	Target Date	Owner
G-04	Compliance Monitoring	NIS2 and DORA gap assessment in progress. Formal compliance tracking tool not yet deployed.	Q2 2026	Risk Manager
G-05	Security Awareness Training	Training programme defined but not yet formally launched. Phishing simulations pending schedule.	Q2 2026	HR / CISO
G-06	Internal Audit	No internal audit completed to date. First audit planned Q3 2026.	Q3 2026	Risk Manager
AC-03	Privileged Access Management	PAM tooling evaluated but JIT access not yet implemented. Manual privileged account controls in place.	Q3 2026	IT Ops
NI-04	Penetration Testing	No penetration test conducted. First external pentest scheduled Q2 2026.	Q2 2026	CISO
IR-04	Regulatory Incident Reporting	NIS2/DORA notification templates in draft. Process not yet tested with regulator.	Q2 2026	CISO
BC-01	Business Continuity Plan	BCP v0.9 drafted. Awaiting final executive review and sign-off.	Q2 2026	Risk Manager
TP-04	Critical ICT Provider Register	DORA-required ICT provider register being populated. Concentration risk analysis not yet complete.	Q3 2026	Risk Manager

5. Review & Maintenance

This control mapping is reviewed annually and updated whenever:

- A new control is implemented or an existing control is significantly changed
- A new regulatory obligation is identified or an existing one is amended
- An internal audit or external assessment identifies gaps or findings
- A significant security incident exposes a control weakness

Document owner is responsible for maintaining version history and communicating updates to control owners.